SEGURIDAD · FRONTERAS DE CONFIANZA

5 CAPAS · 6 FRONTERAS · MODOS DE FALLA · RLS

A DEFENSA EN PROFUNDIDAD

L1 · EDGE
- CSP con nonce por request
- HSTS preload · X-Frame-Options DENY
- updateSession() refresca y redirige

↓

L2 · API
- withErrorHandler + AppError tipados
- rate limit distribuido + allowlist
- validación Zod de todo payload

↓

L3 · MOTOR
- egress-guard SSRF (CIDR + DNS)
- policy-enforcer de plan
- semáforo y timeouts por tool

↓

L4 · DATOS
- withRLS(userId) por transacción
- service_role solo server
- secretos en env-secrets.ts

↓

L5 · OBSERVABILIDAD
- security_audit_logs
- SIEM multi-canal + heartbeat
- Sentry con dataCollection mínimo

B FRONTERAS DE CONFIANZA

ID	FRONTERA	CONTROL REAL
TB-1	Cliente → Edge	CSP nonce · HSTS · X-Frame-Options · Referrer-Policy · report-uri
TB-2	Edge → Route	updateSession(): refresco de sesión y redirect a /login
TB-3	Route → Dominio	Rate limit fail-closed acotado · circuit breaker fail-open 1.5 s
TB-4	Dominio → Externo	egress-guard: CIDR privados v4/v6 + ::ffff: · DNS revalidado
TB-5	Dominio → DB	withRLS + claims JWT · admin solo server · secretos server-only
TB-6	Sistema → Webhook	Firma HMAC SHA-256 + suscripción de eventos

C MODO DE FALLA DECLARADO

COMPONENTE	MODO	COMPORTAMIENTO
Rate limit	FAIL-CLOSED	Si el store cae, sigue limitando en memoria + techo por instancia
Egress guard	FAIL-CLOSED	Ante duda de resolución, bloquea la salida
Circuit breaker	FAIL-OPEN	Servicio auxiliar: se salta y se degrada, nunca tumba la app
Caché L2	FAIL-OPEN	Se ignora y se consulta el origen
IA	DEGRADACIÓN	Onboarding si no hay key; failover; error accionable si todo falla

EGRESS GUARD · SSRF

Solo http: y https:.
Bloquea loopback, link-local, RFC1918, 0.0.0.0/8, 198.18/15, 169.254/16 y ::ffff:x.x.x.x.
Revalida cada redirect y usa User-Agent propio.

CABECERAS Y CSP

default-src 'self'
script-src 'nonce-…' 'strict-dynamic'
object-src 'none' · frame-ancestors 'none'
connect-src 'self' + Supabase
HSTS 31536000 · includeSubDomains
Permisos de navegador restringidos

D RLS — SECUENCIA TRANSACCIONAL

01	BEGIN	abre transacción
02	set_config('request.jwt.claims', claims, true)	claims con sub = userId
03	set_config('role', 'authenticated', true)	rol efectivo solo en la tx
04	…queries del callback…	policies filtran por sub
05	COMMIT	el rol vuelve al de sesión

INVARIANTES

Nunca SET ROLE sin LOCAL. Nunca confiar en el projectId del cliente. Nunca consultar sin RLS fuera del backend de jobs. Nunca devolver stack traces.

1 roundtrip por transacción
(TD-28a verificado en Postgres)

E AMENAZAS → CONTROL (STRIDE)

AMENAZA	SUPERFICIE	CONTROL
Spoofing	login / callback	Magic Link + allowlist de email + rate limit
Tampering	HTTP en tránsito	HSTS + upgrade-insecure-requests + egress-guard
Repudiation	acciones de usuario	security_audit_logs + exportador SIEM
Information disclosure	APIs multi-tenant	RLS + auth + service_role solo server
Denial of service	endpoints y motor	rate limit acotado + semáforos + timeouts
Elevation of privilege	datos de proyecto	RLS por claim sub + autorización owner-only

NOTAS

01 Los controles son independientes: la caída de uno no anula los demás (defensa en profundidad).
02 La autorización es owner-only: el user_id sale del token, jamás del body.
03 Los logs de seguridad se escriben con logSecurityEvent() y alimentan el exportador SIEM.

STRATEGICAUDIT PRO — ATLAS TÉCNICO
ARQUITECTURA DE SOFTWARE

CAD

Qué protege cada capa y cómo falla

Nº PLANO	SCAUDIT-CAD-06	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	06 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO